

PHISHING AWARENESS TRAINING

Understanding, Identifying, and Preventing Phishing Attacks

Title: Phishing Awareness Training

Subtitle: Recognizing and Preventing Social Engineering Attacks

Prepared by: Ubong Okon Solomon

WHAT IS PHISHING?

Phishing is a social engineering attack where attackers impersonate trusted organizations or individuals to trick victims into revealing sensitive information such as: usernames and passwords, bank details, TPs / MFA codes, Personal identity information etc.

✦ Attackers usually use:

- **Email Phishing:** Standard malicious links or spoofed login pages.
- **Smishing:** Deceptive SMS text messages.
- **Vishing:** Voice phishing (e.g., impersonating bank or IT support over the phone).
- **Business Email Compromise (BEC):** Impersonating executives or vendors to divert wire transfers

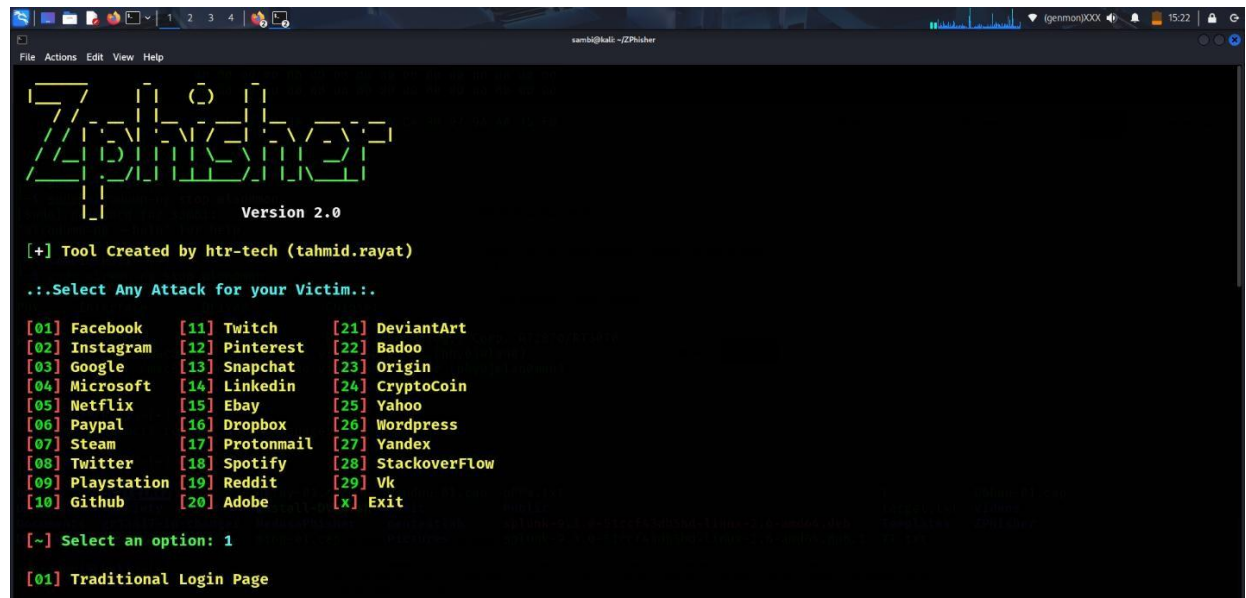
Key Idea: It targets *human psychology*, not systems.

HOW PHISHING WORKS (SIMPLIFIED FLOW)

1. Attacker creates fake page/email
2. Victim receives message (email/SMS/link)
3. Victim clicks link
4. Fake login page opens
5. Credentials are entered
6. Data is captured by attacker

Real world example of a phishing attack on a Facebook account in a controlled environments
using the following tools:

- Tool: MedusaPhisher / Zphisher
- Platform: Linux Environment
- Target Simulation: Facebook login page clone
- Network: Controlled lab setup



```
samb@kali:~/Zphisher
File Actions Edit View Help

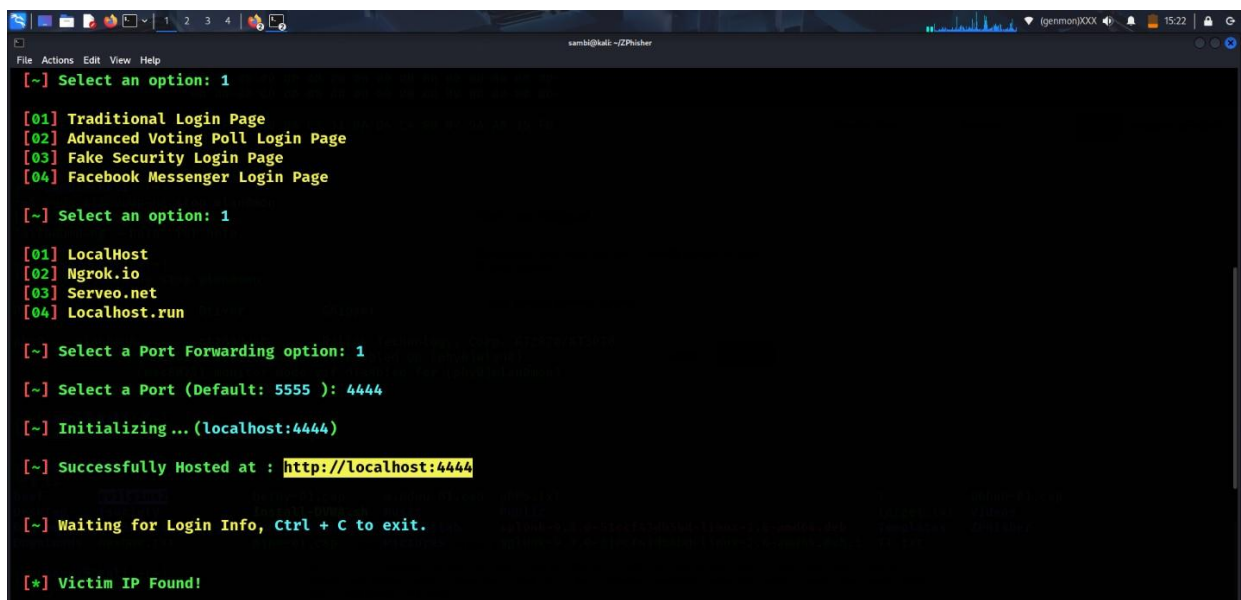
  ZPHISHER
  Version 2.0

[+] Tool Created by htr-tech (tahmid.rayat)

..Select Any Attack for your Victim..

[01] Facebook    [11] Twitch    [21] DeviantArt
[02] Instagram   [12] Pinterest [22] Badoo
[03] Google      [13] Snapchat  [23] Origin
[04] Microsoft   [14] LinkedIn  [24] CryptoCoin
[05] Netflix     [15] Ebay      [25] Yahoo
[06] Paypal      [16] Dropbox   [26] Wordpress
[07] Steam       [17] Protonmail [27] Yandex
[08] Twitter     [18] Spotify   [28] StackoverFlow
[09] Playstation [19] Reddit    [29] Vk
[10] Github      [20] Adobe     [x] Exit

[~] Select an option: 1
[01] Traditional Login Page
```



```
samb@kali:~/Zphisher
File Actions Edit View Help

[~] Select an option: 1

[01] Traditional Login Page
[02] Advanced Voting Poll Login Page
[03] Fake Security Login Page
[04] Facebook Messenger Login Page

[~] Select an option: 1

[01] LocalHost
[02] Ngrok.io
[03] Serveo.net
[04] Localhost.run

[~] Select a Port Forwarding option: 1

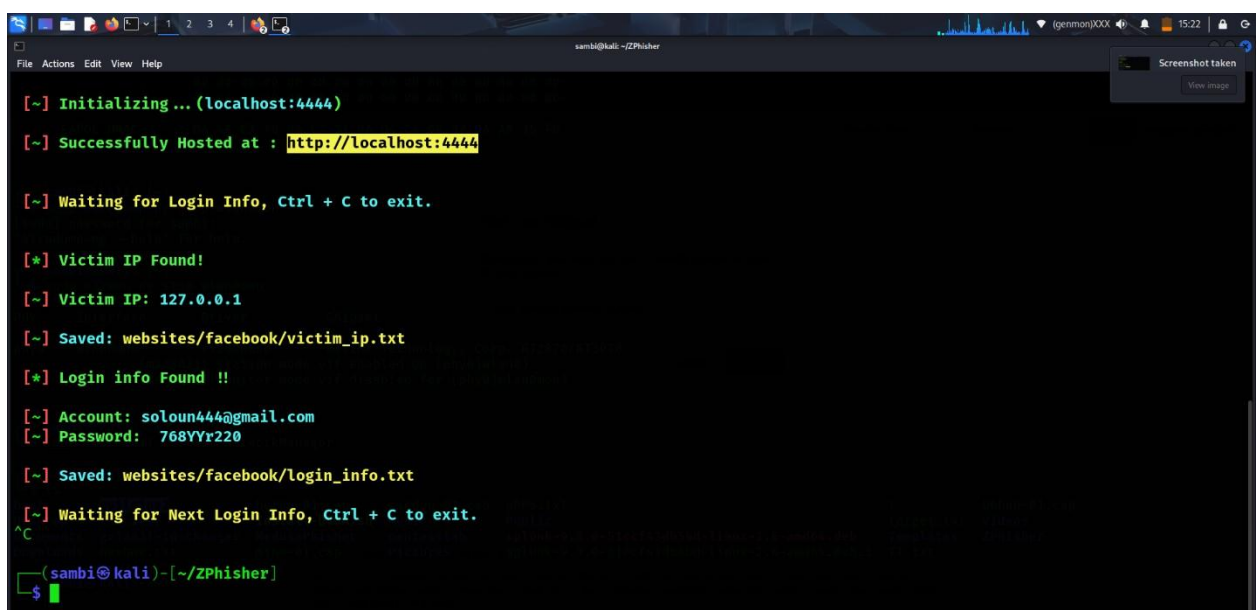
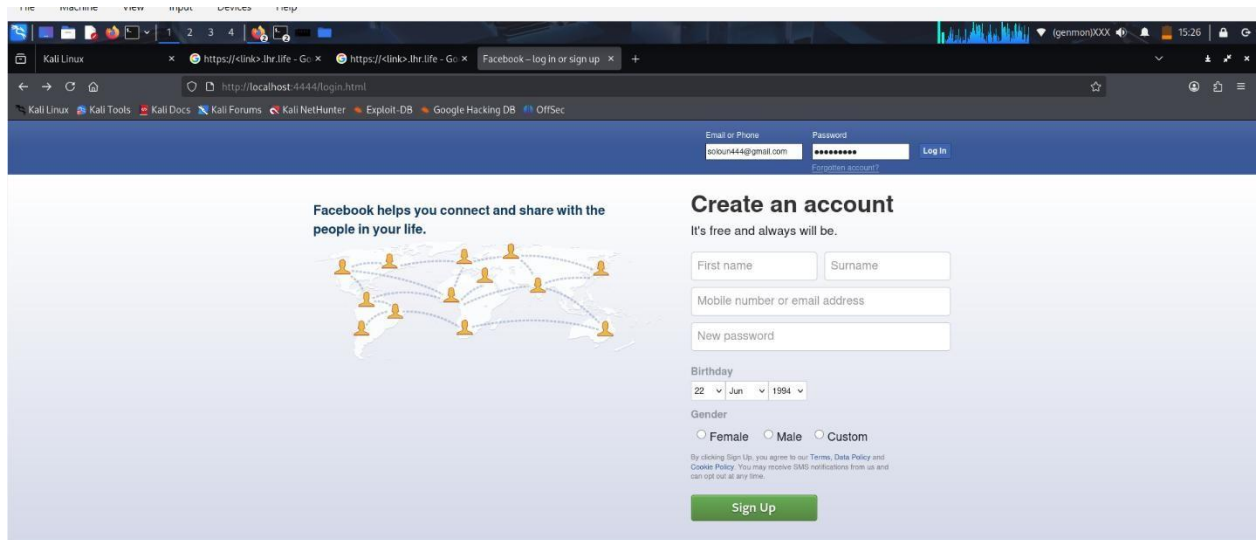
[~] Select a Port (Default: 5555 ): 4444

[~] Initializing ... (localhost:4444)

[~] Successfully Hosted at : http://localhost:4444

[~] Waiting for Login Info, Ctrl + C to exit.

[*] Victim IP Found!
```



These screenshots were taken in a controlled personal laboratory environment to demonstrate how user credentials can be harvested when users interact with a fake login page, such as a cloned Facebook login interface with a malicious URL designed for phishing simulation purposes. This shows what a real-world phishing attack will look like.

⚠ Suspicious Indicators:

- Urgency pressure
- Fake link: facebook-security-login.com
- Poor grammar or formatting
- Unusual sender address

📌 What happens:

User clicks → fake login page → credentials stolen

SOCIAL ENGINEERING TECHNIQUES

Attackers manipulate human behavior using:

- **Urgency:** “Act now or account will be suspended”
- **Authority:** Pretending to be bank/IT admin
- **Fear:** “Unauthorized login detected”
- **Curiosity:** “See who viewed your profile”
- **Reward:** “You’ve won a prize”

📌 Core principle: *Emotional manipulation over technical hacking*

HOW TO IDENTIFY PHISHING EMAILS

Attackers rely on deception to make their malicious platforms look identical to legitimate ones. Here is how you can spot the fakes.

Warning Signs in Emails:

- **Mismatched Domains:** The display name says "Google Support" but the actual email address is support@google-security-update.com. Always check the sender's full address.
- **Grammar and Spelling:** Poorly written content, erratic capitalization, and strange phrasing are huge red flags.
- **Suspicious Attachments:** Unexpected files—especially .exe, .zip, or even macro-enabled .docx files—should never be opened.

📌 Tip:

Always verify sender identity independently

HOW TO DETECT FAKE WEBSITES

Look for:

- HTTP instead of HTTPS
- Misspelled domain names
 - faceb00k.com ❌
 - facebook.com ✓
- Poor UI design or broken layout
- No valid security certificate
- Login page appearing outside official domain

📌 Best Practice:

Always type URL manually instead of clicking links

BEST PRACTICES TO STAY SAFE

Building a strong security culture comes down to a few fundamental habits:

- **Verify Before Acting:** Never click links or download attachments from unexpected messages. If it seems official, contact the organization directly using a trusted channel (e.g., calling an official phone number or navigating to their website manually).
- **Never Share Credentials:** Legitimate companies will never email or text you asking for your password or Multi-Factor Authentication (MFA) codes.
- **Enable MFA:** Always use **Multi-Factor Authentication** wherever available to add a layer of security.
- **Use strong, unique passwords**
Create complex passwords for each account to prevent attackers from accessing multiple services if one password is compromised.
- **Keep software and browsers updated**
Regular updates patch security vulnerabilities, reducing exposure to malware, phishing exploits, and browser-based attacks from cybercriminals.

- **Use anti-phishing browser protection**

Enable built-in browser security tools that detect and block malicious websites and warn users about suspected phishing attempts.

INTERACTIVE QUIZ

Interactive engagement solidifies learning. Below is a quick assessment to test our phishing IQ.

Q1: You receive an urgent email from your bank stating your account will be permanently closed in 24 hours due to "unusual activity." It provides a "Secure Login" link. What should you do?

- A) Click the link and log in immediately to secure your account.
- B) Hover over the link to inspect the URL, then navigate directly to your bank's known website to log in.
- C) Reply to the email asking for more details.

Answer: B. Urgency and fear are classic social engineering tactics. Never use links provided in unsolicited messages.

Q2: An email arrives from "HR Support" with an attachment titled Company_Policy_Update.pdf.exe. Should you open it?

- A) Yes, it is an important policy update.
- B) Yes, but only if you scan it with antivirus software first.
- C) No, executable files (.exe) should never be opened unless explicitly expected and verified.

Answer: C. Executable files hidden behind deceptive names are a common way attackers install malware or ransomware.

Q3: What is the most reliable way to check if an email with a link is safe before clicking?

- A) Look at the display name of the sender.
- B) Hover your mouse over the link to see the actual destination URL in the preview window.
- C) Check if the email uses proper grammar.

Answer: B. Display names and grammar can be easily forged, but hovering over the link reveals exactly where you are being directed.

Q4: What is the safest action if you receive an unexpected email asking you to reset your password?

- A) Click the reset link immediately to secure your account
- B) Reply to the email asking for confirmation
- C) Go directly to the official website and reset your password from there

Answer: C. Phishing emails often contain fake reset links. The safest approach is to manually access the official website instead of using embedded links.

Q5: Which of the following is a strong indicator that a website may be fake?

- A) The website uses HTTPS encryption
- B) The domain name contains slight misspellings or unusual characters
- C) The page loads quickly and looks modern

Answer: B. Attackers often create lookalike domains with minor spelling changes to trick users into believing the site is legitimate.

Q6: What is the main purpose of Multi-Factor Authentication (MFA) in cybersecurity?

- A) To make passwords easier to remember
- B) To add an extra layer of verification beyond just a password
- C) To automatically block all phishing emails

Answer: B. MFA strengthens account security by requiring additional verification (such as a code or app approval), even if a password is compromised.

CONCLUSION

Phishing attacks remain a major cybersecurity threat because they exploit human behavior rather than system weaknesses. This training demonstrates how attackers use fake emails and websites to steal credentials. Staying safe requires simple but consistent practices such as verifying links, using multi-factor authentication, avoiding email login links, and keeping systems updated. With strong awareness and caution, users can effectively reduce the risk of falling victim to phishing attacks.